



1 Objectivos

A componente de avaliação contínua da disciplina de Segurança Informática pretende familiarizar os alunos com alguns dos problemas envolvidos na programação de aplicações distribuídas seguras, nomeadamente a gestão de chaves criptográficas, cifras e assinaturas digitais. O trabalho será realizado utilizando a linguagem de programação Java e a API de segurança do Java.

O trabalho tem como objetivo fundamental a construção de uma aplicação distribuída. O trabalho consiste na concretização de um sistema **simplificado** de armazenamento de ficheiros, designado por **mySaude**, onde os utilizadores usam um servidor central para armazenar **ficheiros** de utentes (resultados de exames, declarações, prescrições, etc).

2 Arquitectura do Sistema

O trabalho consiste no desenvolvimento de ~~três~~dois programas:

- O servidor *mySaudeServer*,
- A aplicação cliente *mySaude* que acede ao servidor via *sockets* TCP, e
- ~~criarUser~~

A aplicação é distribuída de forma que o servidor fica numa máquina e o utilizador pode usar clientes em máquinas diferentes na Internet.

3 Funcionalidades

O sistema tem os seguintes requisitos:

1. O servidor recebe na linha de comandos a seguinte informação:

- Porto (TCP) para aceitar ligações de clientes.

2. Enviar e receber ficheiros do cliente para o servidor e vice-versa

`mySaude -s endereço:porto_do_servidor -u username -e nomes_de_ficheiros -t username_do_destinatario`

`mySaude -s endereço:porto_do_servidor -u username -r nomes_de_ficheiros`

em que:

- a opção `-s` é usada para indicar o endereço IP e o porto do servidor
- a opção `-e` é usada **apenas** para enviar ficheiros para o servidor. Os ficheiros devem se colocados na diretoria do servidor criada para o utilizador `username_do_destinatario`. Devem estar previstos os seguintes erros: diretoria do utilizador não existe no servidor, ficheiro não existe do lado do cliente, ficheiro já existe do lado do servidor. Caso surja uma condição de erro em algum ficheiro, o comando deve continuar para os ficheiros seguintes.

`mySaude -s 10.101.149.5:23456 -u maria -e aa.pdf dd.pdf -t silva`

- a opção `-r` é usada **apenas** para receber ficheiros do servidor. Na linha de comandos, devem ser

indicados todos os ficheiros a receber explicitamente. Devem estar previstos os casos de erro idênticos aos da opção -e. Para receber os ficheiros enviados no exemplo anterior será executado o comando:

```
mySaude -s 10.101.149.5:23456 -u silva -r aa.pdf dd.pdf
```

Obs: no trabalho 1, os utilizadores não são autenticados, i.e., o servidor não verifica a existência ou a autenticidade dos utilizadores. Esta funcionalidade será assegurada no trabalho 2. As passwords utilizadas nas opções seguintes são apenas para acesso às *keystores*. Para evitar erros de concretização, os grupos devem definir passwords diferentes para os utilizadores.

3. Cifrar/decifrar ficheiros

```
mySaude -u username -p password -c nomes_de_ficheiros -t username_do_destinatario
```

```
mySaude -u username -p password -d nomes_de_ficheiros
```

em que:

- o *username* e a *password* são utilizados para identificar o utilizador que está a executar o comando e a *password* de acesso à **keystore deste utilizador**
- assume-se que a *keystore* do utilizador já existe e é designada por *keystore.username*. Por exemplo, o utilizador maria tem uma *keystore* designada por *keystore.maria*. O *username* coincide com o *alias* na *keystore*. A *keystore* de cada utilizador deve ter os certificados necessários para a execução dos comandos. Caso os certificados necessários não existam, o comando deve dar erro. A criação das *keystores* e a importação dos certificados devem ser realizadas manualmente com o comando *keytool*.
- a opção -c cifra os ficheiros *nomes_de_ficheiros* utilizando um mecanismo de cifra híbrida. As chaves assimétricas dos utilizadores estão guardadas na *keystore*. Devem ser utilizadas chaves e algoritmos considerados seguros. A chave cifrada deve ser colocada num ficheiro com nome *nome_de_ficheiro.chave.username_do_destinatario*. O ficheiro cifrado deve ter o nome *nome_de_ficheiro.cifrado*

Exemplo de utilização:

```
mySaude -u maria -p passMaria -c bb.pdf gg.pdf -t silva
```

Este comando cifra os ficheiros *bb.pdf* e *gg.pdf* de modo que apenas o utilizador *silva* possa decifrá-los. Este comando cria os seguintes ficheiros: *bb.pdf.cifrado* e *bb.pdf.chave.silva* e *gg.pdf.cifrado* e *gg.pdf.chave.silva*

- a opção -d decifra os ficheiros *nomes_de_ficheiros* utilizando as chaves guardadas nos ficheiros *nome_de_ficheiro.chave.username_do_destinatario*

Exemplo de utilização:

```
mySaude -u silva -p passSilva -d bb.pdf.cifrado
```

Neste exemplo, a chave para decifrar o ficheiro deve estar em *bb.pdf.chave.silva*. Caso este ficheiro não existe, o comando deve apresentar uma mensagem de erro ao utilizador.

- estas opções do cliente não contactam com o servidor

4. Cifrar/decifrar ficheiros e enviar/receber

```
mySaude -s endereço:porto do servidor -u username -p password -ce nomes_de_ficheiros -t username_do_destinatario
```

```
mySaude -s endereço:porto do servidor -u username -p password -rd nomes_de_ficheiros
```

em que:

- a opção `-ce` cifra os ficheiros e envia para o servidor os ficheiros cifrados e as respectivas chaves (ver descrição das opções `-c` e `-e`)
- a opção `-rd` recebe os ficheiros do servidor e as respectivas chaves e decifra-os (ver descrição das opções `-d` e `-r`)

5. Assinar/validar a assinatura de ficheiros

`mySaude -u username -p password -a nomes_de_ficheiros`

`mySaude -u username -p password -v nomes_de_ficheiros -t username_de_quem_assinou`

em que:

- a opção `-a` assina os ficheiros *nomes_de_ficheiros*. As chaves assimétricas do utilizador estão guardadas na *keystore*. Devem ser utilizadas chaves e algoritmos considerados seguros. A assinatura de cada ficheiro deve ser colocada num ficheiro com nome *nome_de_ficheiro.assinatura.username*

Exemplo de utilização:

`mySaude -u maria -p passMaria -a ee.pdf nn.pdf`

Este comando gera as assinaturas dos ficheiros `ee.pdf` `nn.pdf`. Este comando cria os seguintes ficheiros: `ee.pdf.assinatura.maria`, `nn.pdf.assinatura.maria`

- a opção `-v` verifica a assinatura dos ficheiros *nomes_de_ficheiros*, utilizando as assinaturas guardadas em ficheiros com nomes do tipo: *nome_de_ficheiro.assinatura.username_de_quem_assinou*.

Exemplo de utilização:

`mySaude -u silva -p passSilva -v ee.pdf -t maria`

Este comando valida a assinatura do ficheiro `ee.pdf`, a qual está guardada em `ee.pdf.assinatura.maria`

- **estas opções do cliente não contactam com o servidor**

6. Assinar/validar a assinatura de ficheiros e enviar/receber os ficheiros e assinaturas

`mySaude -s endereço:porto do servidor -u username -p password -ae nomes_de_ficheiros -t username_do_destinatario`

`mySaude -s endereço:porto do servidor -u username -p password -rv nomes_de_ficheiros -t username_de_quem_assinou`

em que:

- a opção `-ae` assina os ficheiros e envia para o servidor os ficheiros e as respectivas assinaturas (ver descrição das opções `-a` e `-e`).

Os ficheiros e as assinaturas enviados devem ser guardados no servidor com os seguintes nomes: *nome_de_ficheiro.assinado*, *nome_de_ficheiro.assinatura.username_de_quem_assinou*

- a opção `-rv` recebe os ficheiros do servidor e as respectivas assinaturas e valida-as (ver descrição das opções `-v` e `-r`)

7. Assinar, cifra e envia / recebe, decifra e verifica assinatura (envelope seguro)

`mySaude -s endereço:porto do servidor -u username -p password -ace nomes_de_ficheiros -t`

username_do_destinatario

mySaude -s endereço:porto do servidor -u *username* -p *password* -rdv *nomes_de_ficheiros* -t *username_de_quem_assinou*

em que:

- a opção -ace assina os ficheiros, cifra-os e envia para o servidor os ficheiros cifrados e as respectivas chaves cifradas e assinaturas (ver descrição das opções -a, -c e -e)

Os ficheiros cifrados, as assinaturas, e as chaves cifradas enviados devem ser guardados no servidor com os seguintes nomes: *nome_de_ficheiro.envelope*,
nome_de_ficheiro.assinatura.username_de_quem_assinou,
nome_de_ficheiro.chave.username_do_destinatario

- a opção -rdv recebe os ficheiros do servidor e as respectivas chaves cifradas e assinaturas. Decifra os ficheiros e valida as assinaturas (ver descrição das opções -v, -d e -r)

Obs: O cliente usa **envelopes seguros mas para simplificar o trabalho, os alunos não precisam de cifrar a assinatura.**

A **unicidade dos nomes dos ficheiros** no servidor deve ser assegurada qualquer que seja a opção com que foram enviados, para o mesmo destinatário, ou seja, caso um ficheiro seja enviado com a opção ce para a maria, caso volte a ser enviado para a maria com a opção ae ou com qualquer outra opção, o cliente deve dar erro. Assim, para o mesmo utilizador, não devem ser admitidos os seguintes ficheiros no servidor, em simultâneo: aa.pdf, aa.pdf.cifrado, aa.pdf.assinado e aa.pdf.envelope. Caso um deles já exista, na tentativa de criação dos seguintes, o cliente deve apresentar um erro ao utilizador.

Toda criptografia assimétrica no trabalho deve usar RSA com chaves de 2048 bits. A criptografia simétrica deve ser efetuada com AES e chaves de 128 bits.

4 Critérios de avaliação

A avaliação dos projetos será feita segundo uma abordagem funcional, onde cada funcionalidade descrita no enunciado deve ser apresentada pelos alunos. **Não serão consideradas funcionalidades incompletas ou valorizada qualquer implementação não funcional.** É obrigatório apresentarem os projetos em duas máquinas distintas do laboratório (servidor e cliente em máquinas separadas). De preferência, devem utilizar o sistema operativo Linux.

Cada uma das opções/funcionalidades apresentadas será valorizada de acordo com a seguinte tabela.

Funcionalidade	Valorização	Validação
Enviar e receber ficheiros Funciona para ficheiros de qualquer dimensão Funciona para vários ficheiros Trata erros Caso não seja possível comprovar o correto funcionamento das operações será classificado com 0	3	
Cifrar/decifrar Funciona para ficheiros de qualquer dimensão Funciona para vários ficheiros Trata erros Caso não seja possível comprovar o correto funcionamento das operações será classificado com 0	3	
Cifrar/enviar, receber/decifrar Funciona para ficheiros de qualquer dimensão Funciona para vários ficheiros Trata erros	3	

Caso não seja possível comprovar o correto funcionamento das operações será classificado com 0		
Assinar/validar a assinatura de ficheiros Funciona para ficheiros de qualquer dimensão Funciona para vários ficheiros Trata erros Caso não seja possível comprovar o correto funcionamento das operações será classificado com 0	3	
Assinar/enviar e receber/validar ficheiros e assinaturas Funciona para ficheiros de qualquer dimensão Funciona para vários ficheiros Trata erros Caso não seja possível comprovar o correto funcionamento das operações será classificado com 0	3	
Assinar, cifra e envia / recebe, decifra e verifica assinatura (envelope seguro) Funciona para ficheiros de qualquer dimensão Funciona para vários ficheiros Trata erros Caso não seja possível comprovar o correto funcionamento das operações será classificado com 0	3	
Usam algoritmos não seguros	Penalização de 1 valor por cada caso	
Relatório (e entrega dentro do prazo)	1	
Preparação da apresentação para a avaliação e cumprimento do tempo	1	

5 Entrega

Código:

Dia **29 de Março**, até às 23:55 horas. O código do trabalho deve ser entregue da seguinte forma:

- Os grupos devem inscrever-se atempadamente de acordo com as regras afixadas para o efeito, na página da disciplina.
- Na página da disciplina submeter o código do trabalho num ficheiro zip e um readme (txt) sobre como executar o trabalho.

Relatório:

Dia **30 de Março**, até as 12:00 horas, no moodle.

No relatório devem ser apresentados e discutidos os seguintes aspetos:

- Os objetivos concretizados com êxito
- A tabela de autoavaliação de acordo com os critérios definidos
- Os problemas encontrados.

Não serão aceites trabalhos por email nem por qualquer outro meio não definido nesta secção. Se não se verificar algum destes requisitos o trabalho é considerado não entregue.

As avaliações dos trabalhos serão realizadas no dia 31 de Março, durante as aulas. **Todos os elementos do grupo têm de comparecer.**